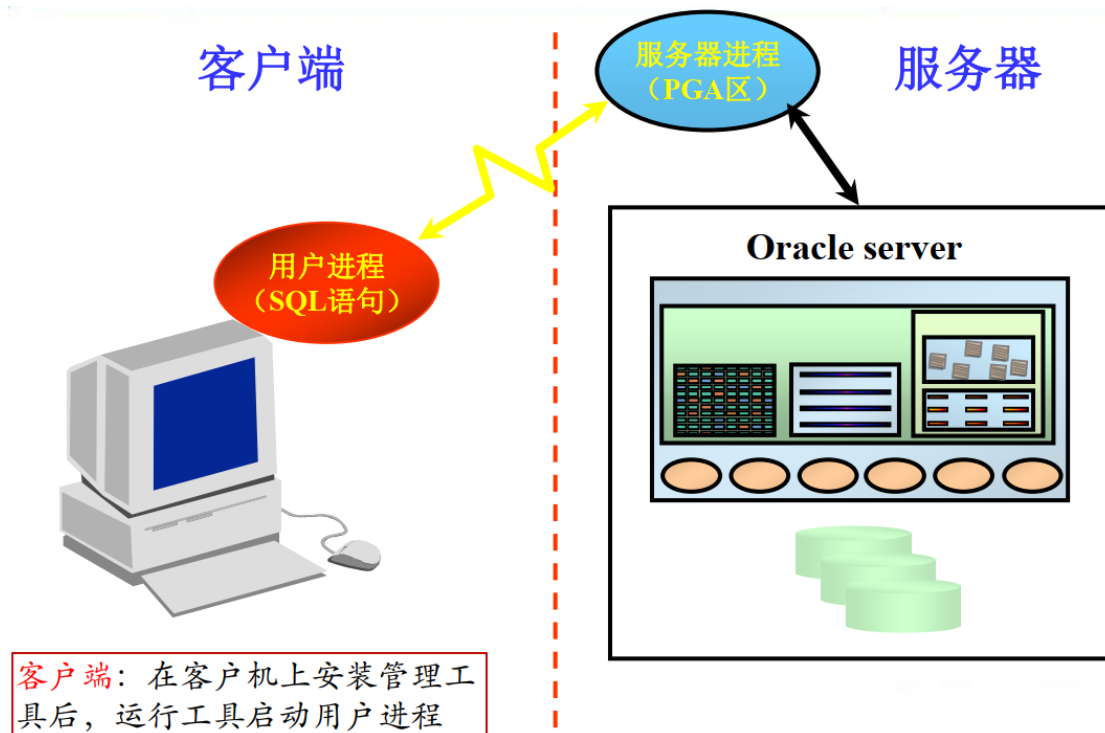


第十二讲 Oracle 安全概述

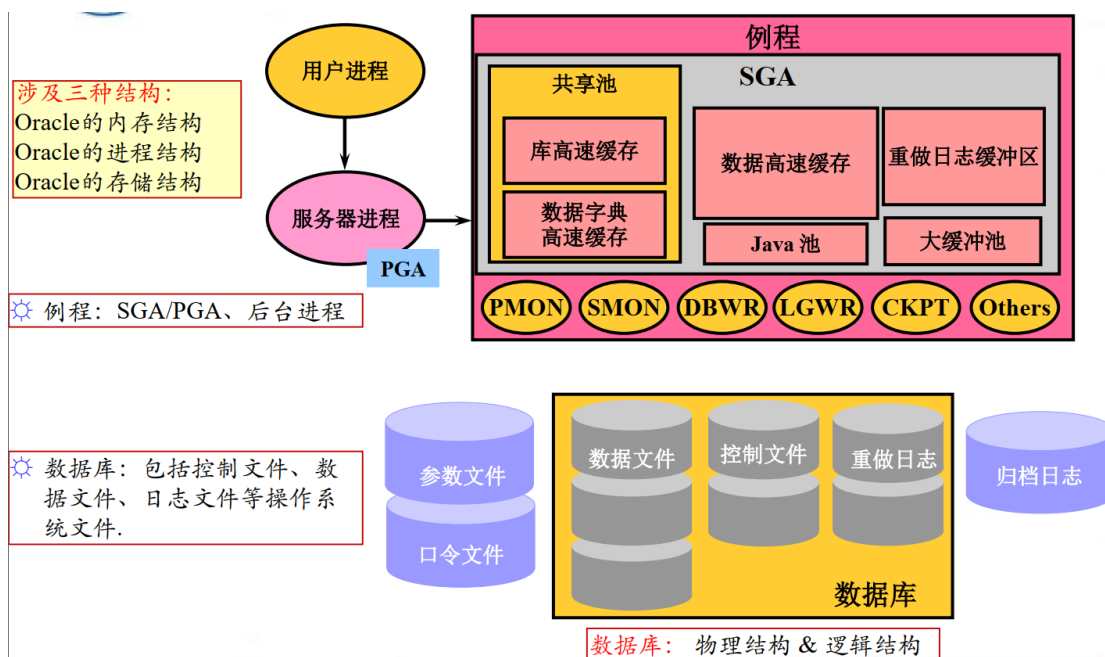
一、Oracle 体系结构

1、Oracle 工作原理

Oracle 的体系结构可分客户端、服务器两大部分。



2、服务端的体系结构：例程+数据库



3、关于例程 (instance)

启动 Oracle 数据库前应先启动 instance。

当用户连接到数据库并使用数据库时，实际上是连接到该数据库的例程，通过例程来连接、使用数据库。

所以例程是用户和数据库之间的中间层。

例程与数据库的区别：

- 数据库指的是存储数据的物理结构，总是实际存在的；
- 例程则是由内存结构和一系列进程组成，可以启动和关闭。

4、Oracle 数据库的三种结构

内存结构

- SGA 和 PGA，使用内存最多的是 SGA，同时也是影响数据库性能的最大参数

进程结构

- 包括前台进程、后台进程
- 前台进程是指服务进程和用户进程。前台进程是根据实际需要而运行的，并在需要结束后立刻结束

- 后台进程是指在 Oracle 数据库启动后，自动启动的几个操作系统进程

存储结构

- 分为逻辑存储结构、物理存储结构
- 逻辑存储结构是描述 Oracle 数据库中如何组织和管理数据，与操作系统平台无关

- 物理存储结构是数据库的外部存储结构。它对应操作系统相关文件，包括控制文件、数据文件、日志文件等操作系统文件

5、Oracle 数据库的三种结构： 存储结构

Oracle 保存数据的容器。分物理存储结构及逻辑存储结构。

(1) Oracle 数据库物理存储结构

物理存储结构是现实的数据存储单元，对应于操作系统文件。

Oracle 数据库就是由驻留在服务器的磁盘上的这些操作系统文件所组成的，包括数据文件、日志文件、控制文件。

物理结构主要包括以下三种文件：

- 控制文件 (.ctl)
- 数据文件 (.dbf)
- 重做日志 (.log)

①Oracle 数据库物理存储结构： 数据文件

数据文件 (Data File) 是物理存储 Oracle 数据库数据的文件。

其特点如下：

- 每一个数据文件只与一个数据库相联系
- 一个表空间可包含一个或多个数据文件
- 一个数据文件只能属于一个表空间

②Oracle 数据库物理存储结构： 重做日志文件

重做日志文件 (Redo Log File) 记录所有对数据库数据的修改，以备恢复数据时使用。

其特点如下：

- 每一个数据库至少包含两个日志文件组
- 日志文件组以循环方式进行写操作
- 每一个日志文件成员对应一个物理文件

③Oracle 数据库物理存储结构： 控制文件

控制文件（Control File）是一个较小的二进制文件，用于描述数据库结构。

描述信息：

- 数据库建立的日期
- 数据库名
- 数据库中所有数据文件和日志文件的文件名及路径
- 恢复数据库时所需的同步信息

要点注意：

- 在打开和存取数据库时都要访问该文件
- 记录控制文件名及路径的参数为 CONTROL_FILES

可以将控制文件理解为物理数据库的一个元数据存储库

④Oracle 数据库物理存储结构： 参数文件

参数文件（Parameter File）也被称为初始化参数文件，用于存储 SGA、可选的 Oracle 特性和后台进程的配置参数。

当数据库启动，并在创建例程或读取控制文件之前，会先按其
中的参数进行例程的配置。

位置： \$Oracle_home\ dbs \ init.ora

⑤Oracle 数据库物理存储结构： 口令文件

口令文件：是个二进制文件，验证特权用户

位置： \$Oracle_home\ database\PWD%.ora

(windows 口令文件位置： C:\windows\System32\config\SAM)

归档日志文件： 非活动的重做日志文件的备份

(2) Oracle 数据库逻辑存储结构

主要描述 Oracle 数据库的内部存储结构，从技术概念上描述

Oracle 数据库中如何组织、管理数据

可以分为 4 部分：表空间、段、区、块

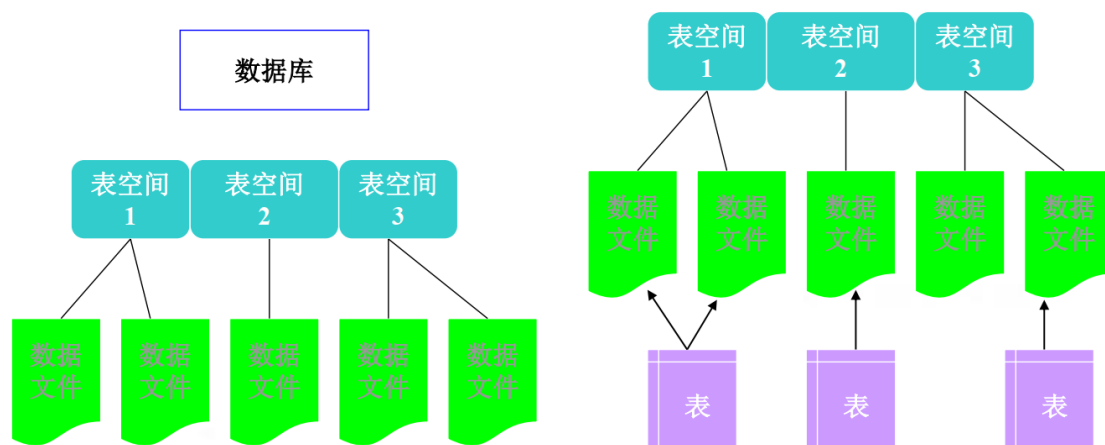
Oracle 的逻辑结构是由一个或多个表空间组成

- 一个表空间 (tablespace) 由一组段组成
- 一个段 (segment) 由一组区组成
- 一个区 (extent) 由一批数据库块组成
- 一个数据库块 (block) 对应一个或多个物理操作系统块

①Oracle 数据库逻辑存储结构： 表空间

表空间是数据库的逻辑划分的最大单元，一个 Oracle 数据库至少有一个表空间，即 system 表空间。表空间的设计理念为 Oracle 的高性能做出了不可磨灭的贡献，其很多优化都是基于该理念而实现的。

表空间是 ORACLE 数据库恢复的最小单位，容纳着许多数据库实体 如表、视图、索引、聚簇、回退段和临时段等。



②Oracle 数据库逻辑存储结构： 典型应用

I 典型应用一： 控制用户所占用的表空间配额

在一些大型的数据库应用中，DBA 需要控制某个用户或者某一组用户所占用的磁盘空间。这就好像在文件服务器中，需要为每个用户设置磁盘配额一样，以防止硬盘空间耗竭。所以，在数据库中，我们也需要限制用户所可以使用的磁盘空间大小。

可以通过表空间来实现这个目的。 DBA 在 Oracle 数据库中，建立不同的表空间，为其设置最大的存储容量，然后把用户归属于这个表空间。

如此的话，这个用户的存储容量，就受到这个表空间大小的限制。

II 典型应用二： 控制数据库所占用的磁盘空间

有时候，在 Oracle 数据库服务器中，可能运行的不止一个服务。除了数据库服务器外，可能还有邮件服务器等应用系统服务器。为此，就需要先对 Oracle 数据库的磁盘空间作个规划，否则当多个应用程序服务所占用的磁盘空间都无限增加时， 最后可能导致各个服务都因为硬盘空间的耗竭而停止。

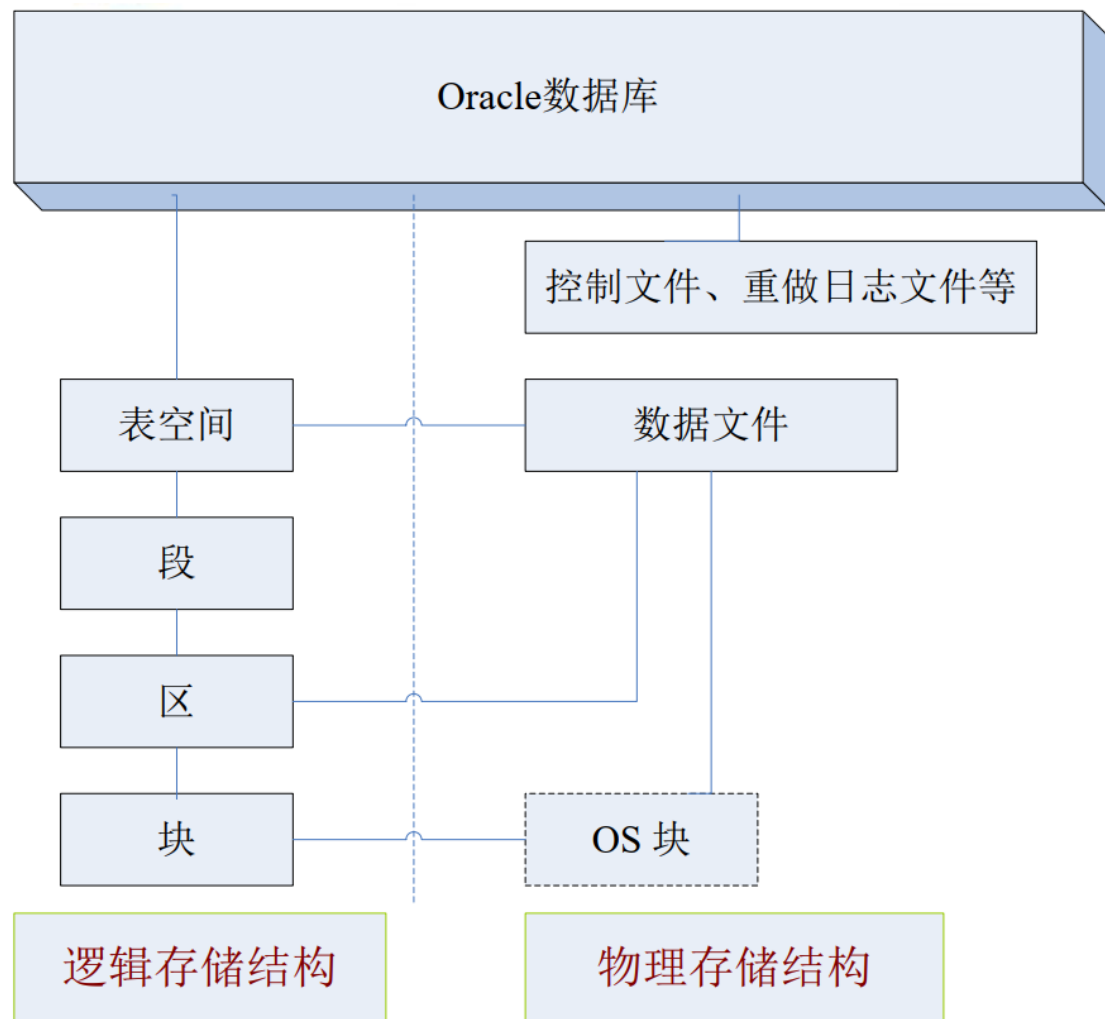
在同一台服务器上使用多个应用程序服务，往往需要先给它们进行磁盘空间的规划和分配。各个服务都不能够超过最大限额，或者超过后及时发出警报。

(3) Oracle 存储结构： 小结

□ 物理上看，数据库由控制文件、数据文件、重做日志文件等操作系统文件组成。

□ 从逻辑上来看，数据库是由系统表空间、用户表空间等组成。

□ 表空间是最大的逻辑单位，块是最小的逻辑单位。



物理存储结构与逻辑存储结构之间的关系

6、Oracle 数据库的三种结构： 内存结构

Oracle 内存结构由两个部分组成：

- 系统全局区 (SGA) — 在启动例程时分配，是 Oracle 例程的基础组件

- 程序全局区 (PGA) — 当启动服务器进程时分配

(1) 系统全局区 (SGA)

SGA 是 ORACLE 系统为例程分配的一组共享缓冲存储区，用于存放数据库数据和控制信息，以实现数据库数据的管理和操作。

SGA 是不同用户进程与服务进程进行通信的中心。

数据库的各种操作主要在 SGA 中进行，所以称其为系统全局区。

- 每个例程都只有一个 SGA
- 创建例程时， Oracle 为 SGA 分配内存
- 终止例程时，释放 SGA 所占用的内存

- SGA 由以下内存结构组成

- 共享池
- 数据高速缓存
- 重做日志缓冲区

- 在 SGA 内可以配置以下内存结构

- 大缓冲池
- Java 池

①共享池

- 用于存储:
 - 最近执行的 SQL 语句
 - 最近使用的数据定义
- 由两个关键的内存结构组成:
 - 库高速缓存
 - 数据字典高速缓存
- 尺寸由参数 SHARED_POOL_SIZE 控制

②数据高速缓存

- 初次访问数据时，Oracle 将读取磁盘上的数据文件，将数据放入数据高速缓存，再处理数据；
- 如果数据已经位于数据高速缓存中时，Oracle 直接操作数据。

③重做日志缓冲区

记录所有数据块变化，主要目的是恢复。

当执行 DML（如 update、delete、insert 或者 create、alter、drop 等语句）时，Oracle 都会为这些操作生成重做记录

- Oracle 总是先记录日志、后记录数据
- 由 LOG_BUFFER 初始化参数定义

④大缓冲池

大缓冲池用于为需要大内存的操作提供相对独立的内存空间，以便提高性能。

大池是可选的内存结构

DBA 可以决定是否需要在 SGA 中创建大池

需要大池的操作

- 数据库备份和恢复
- 大量排序的 SQL 语句
- 并行化的数据库操作

⑤Java 池

• 8i 以后提供的对 Java 的支持，用于存放 Java 代码、Java 程序等。

- 一般不小于 20M，以便虚拟机运行
- 尺寸由 JAVA_POOL_SIZE 控制

(2) 程序全局区 (PGA)

- 为每个连接到数据库的用户进程预留内存
- 当建立服务器进程时分配
- 当终止服务器进程时释放
- 只能由一个进程使用

7、Oracle 数据库的三种结构： 进程结构

Oracle 使用各种类型进程：

- 用户进程：当用户请求连接到 Oracle server 时启动
- 服务进程：连接到例程，并且当用户建立会话时启动
- 后台进程：当启动例程时启动

(1) 用户进程

- 请求与 Oracle server 交互的程序

- 必须首先建立连接
- 不会与 Oracle server 直接交互

(2) 服务器进程

- 直接与 Oracle server 交互的程序
- 完成调用并返回结果
- 可以是专用的或者共享的

(3) 后台进程

作用：维护并加强物理结构和内存结构的关系。

DBWn、LGWR、SMON、PMON、CKPT、ARCn。

8、哪些地方会有安全问题？

(1) 用户连接到例程

- 建立用户连接
- 建立会话
- 会话过程

建立连接是一个安全审核的过程。包括：提交的网络服务名是否正确；输入的用户名及密码是否存在且正确，连接的数据库对象是否存在等，对这些一系列的过程进行审核。

通过用户进程来连接。一旦建立了连接，Oracle 服务器会给该用户调度一个服务器进程来完成该用户的请求命令服务。

服务器进程解析用户进程提交过来的 SQL 语句，完成该次会话执行的各种任务。

(2) 数据安全

文件被窃、文件损坏、资源滥用。

二、Oracle 安全机制

1、传统安全方案的缺陷

(1) 网络防火墙产品不对数据库通信协议进行控制

e.g., TNS 协议是 ORACLE 服务端和客户端通信的协议

(2) IPS/IDS/网络审计并不能防范那些看起来合法的数据访问

(3) WAF 系统仅针对 HTTP 协议进行检测控制，绕过 WAF 有 150 多种方法

(4) 核心数据库防护措施被忽略。大多数系统前端层面的安全保护措施并无法覆盖所有的安全攻击和窃取——必须引入数据层面的保护作为最后一道安全防线。

2、数据库运维面临很多安全隐患

(1) 数据库口令暴露

- 运维、开发人员知晓数据库口令；
- 任意客户端登录；
- 无统一访问出入口

(2) 存在高危操作

- 随意操作数据库对象；
- 恶意操作行为；
- 误操作、高危操作

(3) 用户身份不清

- 公用设备、公用账户

安全运维需要规范运维行为，具体包括三点：

- ①身份识别：解决口令外泄，区分人员身份
- ②访问审批：预防高危操作，避免越权操作
- ③流程管理：规范流程管理，有效追责定责

3、Oracle 的安全机制

☐ 数据的备份与恢复

➤ 为保证数据的完整性和一致性，防止因故障而导致的数据破坏和灾难而采取的防范措施。

☐ 用户管理

➤ 用户身份认证、角色与权限等。

☐ 资源管理

➤ 通过系统概要文件限制连接会话等。

(1) 用户管理

☐ 用户类别

- 在数据库系统中，根据工作性质和特点，用户可分成三类：数据库管理员（DBA）、数据库开发人员和普通用户。
- 不同类型的用户分别赋予不同的权限，从而保证数据库系统的安全。

☐ 数据库管理员（DBA）

负责管理和维护数据库系统的正常运行，其主要职责包括：

- 安装并升级 Oracle 服务器和应用工具
- 配置和管理数据库

- 设置权限和安全管理
- 监控并优化数据库性能
- 备份和恢复数据库

□ 数据库开发人员

负责设计和开发数据库应用程序，其主要职责包括：

- 设计应用的数据结构
- 估算应用的存储需求
- 给出应用数据库结构修改的说明
- 开发过程中优化应用
- 开发过程中构建应用的安全策略

以上工作需要和 DBA 协作。

□ 普通用户

普通用户指的是执行与数据库相关的日常操作的工作人员。

□ 通过创建、修改、删除和监视用户来控制用户对于 ORACLE

数据库的存取

控制用户对数据库的存取：

①用户必须拥有必要的角色和权限，才能被数据库认可并在数据库中进行相应的活动

②限定每个用户使用磁盘空间的大小。

(2) 权限

权限指的是执行特定命令或访问数据库对象的权利。

权限有两种类型

➤ 系统权限：Oracle 有 80 多种系统权限，可使用户在系统范围内完成特定的操作。

➤ 对象权限：允许用户在被指定用户所属的数据库对象（如表、视图、序列等）完成特定操作。

如何限制 DBA 的权利？Vault。

从宏观方面看，Vault 属于 Oracle 数据库安全领域中-访问控制的部分。

（3）数据的备份恢复

当数据库出现介质或者用户误操作时，使用已备份数据文件、归档日志和重做日志将数据库恢复到备份点与故障点之间某个时刻的状态。

备份和恢复的方法：利用 Oracle 工具程序 EXP 和 IMP（EXPDP 和 IMPDP）将数据库部分或全部对象的结构及其数据导出、导入。

数据泵（Data Pump）是 Oracle 10g 提供的实用程序，它可以从数据库中高速导出或加载数据库的方法，可以自动管理多个并行的数据流。数据泵可以实现在测试环境、开发环境、生产环境以及高级复制或热备份数据库之间的快速数据迁移；数据泵还能实现部分或全部数据库逻辑备份，以及跨平台的可传输表空间备份。